

ĐẶC TẢ API – AUTHENTICATION

Phiên bản: 1.0

Module: Authentication

Đối tượng sử dụng: Frontend (FE) / Backend (BE)

Mục đích: Thống nhất cấu trúc dữ liệu, API Contract và luồng xử lý giữa FE và BE.

1. Quy ước chung

1.1. Base URL

API sử dụng prefix: `/api/v1`

Các endpoint Authentication: `/api/v1/auth/...`

Ví dụ: `POST /api/v1/auth/register`

1.2. Quy ước HTTP Status Code

HTTP Status	Ý nghĩa
200	Request thành công
201	Tạo tài nguyên thành công
400	Dữ liệu request không hợp lệ
401	Chưa xác thực / Token không hợp lệ
403	Không có quyền thực hiện
404	Không tìm thấy tài nguyên
409	Dữ liệu đã tồn tại
422	Dữ liệu không đáp ứng validation

HTTP Status	Ý nghĩa
429	Vượt quá giới hạn request
500	Lỗi hệ thống

2. Cấu trúc Response chung

2.1. Success Response

```
JSON
{
  "success": true,
  "message": "Thao tác thành công",
  "data": {}
}
```

2.2. Error Response

```
JSON
{
  "success": false,
  "code": "ERROR_CODE",
  "message": "Thông báo lỗi",
  "errors": []
}
```

3. Đăng ký tài khoản

Endpoint: `POST /api/v1/auth/register`

3.1. Request Fields

Tên trường	Kiểu	Bắt buộc	Mô tả
fullName	String	Có	Họ và tên người dùng
phone	String	Có	Số điện thoại hợp lệ, chưa tồn tại
email	String	Có	Email hợp lệ, chưa tồn tại
password	String	Có	Mật khẩu theo chính sách bảo mật
confirmPassword	String	Có	Phải trùng khớp với password

3.2. Workflow

1. FE: `POST /auth/register`
2. BE: Validate -> Check Email/Phone -> Hash Password -> Create User (PENDING_VERIFICATION) -> Generate OTP -> Send Email.
3. FE: Chuyển sang verify OTP.

4. Xác thực OTP đăng ký

Endpoint: `POST /api/v1/auth/verify-otp`

4.1. Workflow

1. FE: `POST /auth/verify-otp` (email, otp)
2. BE: Kiểm tra OTP hợp lệ -> Set User = ACTIVE -> Invalidate OTP -> Trả về kết quả.

5. Gửi lại OTP

Endpoint: `POST /api/v1/auth/resent-otp`

5.1. Chính sách

- Length: 6 digits
- Expiration: 5 minutes

- Resend cooldown: 60 seconds

6. Đăng nhập

Endpoint: `POST /api/v1/auth/login`

6.1. Request Fields

Tên trường	Kiểu	Bắt buộc	Mô tả
<code>identifier</code>	String	Có	Email hoặc số điện thoại
<code>password</code>	String	Có	Mật khẩu
<code>rememberMe</code>	Boolean	Không	Ghi nhớ phiên

6.2. Luồng

BE tìm User theo identifier -> Check Password -> Check Status (ACTIVE) -> Generate Tokens -> Return Auth Info.

7. Refresh Access Token

Endpoint: `POST /api/v1/auth/refresh`

Sử dụng Refresh Token để cấp Access Token mới.

8. Đăng xuất

Endpoint: `POST /api/v1/auth/logout`

Invalidate Refresh Token / Session.

9. Đăng nhập qua OAuth (Google / Microsoft)

Endpoint: `POST /api/v1/auth/oauth`

FE gửi Authorization Code -> BE xác thực -> Kiểm tra user (Exists: Login, Not Exists: Create) -> Trả về tokens.

10. Quên & Reset mật khẩu

10.1. Quên mật khẩu

`POST /api/v1/auth/forgot-password`(identifier)

BE gửi OTP.

10.2. Xác thực OTP Reset

`POST /api/v1/auth/verify-reset-otp`(identifier, otp)

BE trả về `resetToken`.

10.3. Đổi mật khẩu

`POST /api/v1/auth/reset-password`(resetToken, newPassword, confirmPassword)

BE validate token -> Hash & Update Password.

11. Security & Policies

11.1. Password Policy

- Hash trước khi lưu.
- Không trả password trong Response.
- ConfirmPassword chỉ để validate, không lưu DB.

11.2. Token Policy

- Access Token: Thời gian sống ngắn, truyền qua Header Authorization.
- Refresh Token: Quản lý bảo mật (HttpOnly Cookie hoặc lưu an toàn).

11.3. API Protection

- Rate Limiting cho các API nhạy cảm (/login, /register, /otp).
- Logging & Audit logs.

12. Trách nhiệm FE & BE

- **FE:** UI/UX, Validate cơ bản, Countdown, Lưu token, Điều hướng.
- **BE:** Nguồn xác thực cuối cùng, Business Logic, Security (Hash, OTP, Validation, DB).

